SK Shieldus Rookies

상세 진단 보고서 (실무진용)

모의 교육 플랫폼 취약점 진단 결과

러닝브릿지(가상) 온라인 교육 플랫폼

문서 번호	SCAN-2026-002-T	**진단 일자**	2026-10-02
진단 대상	모의 교육 플랫폼	**작성일**	2026-10-07
작성	SK쉴더스 루키즈 34기 1석삼조 팀	**대상 독자**	정보보호·개발·운영 담당자

본 보고서는 SK쉴더스 루키즈 교육과정의 프로젝트 산출물이며, SK쉴더스의 공식 진단 보고서가 아닙니다.

1. 진단 개요

1.1 대상 및 범위

자산	자산 ID	개인정보 처리	점검 항목
교육 플랫폼 웹서버	WEB01	처리	2개

1.2 적용 기준

구분	문서	버전	시행일
법률	개인정보 보호법	법률 제21445호	2026-09-11
고시	개인정보의 안전성 확보조치 기준	개인정보보호위원회고시 제2026-9호	2026-07-01
인증기준	ISMS-P 인증기준 안내서	2023.11	-

1.3 법령·인증기준 매핑 방식

취약점과 법령·ISMS-P 인증기준의 매핑은 llm+rule으로 수행했습니다 (모델 gpt-5.5, 프롬프트 v3/n2). 담당자 검토를 마친 매핑은 `검토 완료`, 아직 확인하지 않은 매핑은 `검토 전`으로 표시합니다. 현재 검토 전 매핑은 4건입니다.

2. 진단 결과 요약

점검 2개 항목 중 취약 1개, 양호 1개입니다. 전체 위험 수준은 **심각**(개인정보를 처리하는 자산에 '상' 위험 취약점이 있음)으로 판정했습니다.

2.1 위험도별 현황

위험도	취약 항목
상	1개
중	0개
하	0개

2.2 항목별 결과

항목	점검 항목	대상 자산	위험도	결과
W-03	불충분한 권한 검증	교육 플랫폼 웹서버	상	취약
W-02	약한 비밀번호 정책	교육 플랫폼 웹서버	상	양호

3. 취약점 상세

3.1 불충분한 권한 검증 (W-03) 상

식별 번호	SCAN-2026-002-W-03-WEB01
대상 자산	교육 플랫폼 웹서버 (WEB01), 개인정보 처리
설명	교육 플랫폼 웹서버에서 수강생 계정으로 로그인한 후, 성적 조회 URL의 student_id 값을 다른 번호로 바꾸면 다른 수강생의 개인정보가 조회됩니다. 이는 서버에서 요청자의 본인 여부를 확인하지 않기 때문입니다.
영향	공격자가 이 취약점을 악용할 경우, 수강생의 이름, 연락처, 성적 등 민감한 개인정보가 무단으로 유출될 수 있습니다.
현황	수강생 계정으로 로그인한 뒤 성적 조회 URL의 student_id 값을 다른 번호로 바꾸면 다른 수강생의 이름, 연락처, 성적이 그대로 조회됨. 서버에서 요청자 본인 여부를 확인하지 않음
판단 기준	양호: 중요 페이지에 사용자 검증 로직이 구현되어 있어, 타 사용자의 권한 탈취가 제한된 경우 / 취약: 중요 페이지에 사용자 검증 로직이 미흡하여, 타 사용자의 권한 탈취가 가능한 경우
조치 방법	접근 제어가 필요한 모든 페이지에 서버 사이드 방식 사용자 권한 검증 로직 구현
관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 수강생 계정에서 다른 수강생의 이름, 연락처, 성적이 조회되어 개인정보가 권한 없는 자에게 유출될 수 있는 상태입니다. 이는 접근권한 및 접근통제 등 안전성 확보에 필요한 기술적 조치가 미흡한 경우에 해당합니다. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규) **개인정보의 안전성 확보조치 기준 제5조 제1항(접근 권한의 관리)** 검토 전 ① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다. 매핑 근거: 수강생 계정이 본인 정보 범위를 넘어 다른 수강생의 개인정보와 성적에 접근할 수 있어 개인정보처리시스템 접근 권한이 필요한 최소 범위로 제한·차등 부여되지 않았습니다. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규) **개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제)** 검토 전 ③ 개인정보처리자는 처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하여야 한다. 매핑 근거: 성적 조회 URL의 student_id만 변경하면 인터넷 홈페이지를 통해 권한 없는 수강생에게 다른 수강생의 개인정보가 공개됩니다. 이는 권한 없는 자에게 개인정보가 공개 또는 유출되지 않도록 조치해야 하는 의무에 어긋납니다. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규)

ISMS-P	**2.6.3 응용프로그램 접근** 검토 전 매핑 근거: 수강생이 성적 조회 URL의 student_id 값을 변경하여 다른 수강생의 이름, 연락처, 성적을 조회할 수 있어 응용프로그램에서 사용자별 접근권한을 적절히 제한하지 못하고 있습니다. 서버에서 요청자 본인 여부를 확인하지 않아 개인정보 및 중요정보 노출을 최소화하기 위한 접근통제가 미흡합니다.
매핑 검토 메모	LLM 항 판단으로 제외한 조문: SAFE-12 제12조(출력 · 복사시 안전조치): 진단 근거는 URL 파라미터 조작에 따른 권한 검증 미흡과 타인 정보 조회에 관한 내용입니다. 출력 용도 특정, 출력 항목 최소화 또는 출력·복사물 관리 미흡 사실은 제시되지 않았습니다.

4. 부록

4.1 기준 문서 원본

ID	원본 파일
PIPA-21445	개인정보 보호법(법률)(제21445호)(20260911).txt
SAFE-2026-9	개인정보의 안전성 확보조치 기준(고시)(제2026-9호)(20260701).txt
ISMSP-2023.11	ISMS-P 인증기준 안내서(2023.11).txt

4.2 보고서 생성 방식

결과 판정(위험도, 취약·양호, 전체 위험 수준)은 진단 데이터와 정해진 규칙으로 산출했습니다. 설명과 영향 문장은 AI가 작성했으며, 판단 기준과 조치 방법은 항목 카탈로그에서, 법령 조문은 기준 문서 원문에서 그대로 가져왔습니다.

유사 사례는 개인정보보호위원회 처분 보도자료 원문으로 확인한 사례 카드에서 검색했고, 과징금 노출액과 조치 우선순위는 아래 기준으로 코드가 계산했습니다. 금액은 AI를 거치지 않았습니다.

4.3 과징금 노출 산정

항목	값	근거·설명
법정 상한	1억 5,000만 원	전체 매출액에서 위반과 무관한 매출을 뺀 금액의 3%. 개인정보 보호법 제64조의2(과징금의 부과), 2026-09-11 시행 개정법
10% 특례 시나리오	5억 원	고의·중과실로 3년 내 같은 유형 반복 위반: 해당 없음 (고객사 프로필의 3년 내 위반 이력 기준. 고의·중과실 여부는 도구가 판단하지 않음) 고의·중과실로 피해 1천만 명 이상: 해당 없음 (정보주체 120,000명 → 1천만 명 기준 미달) 시정명령 불이행으로 유출: 해당 없음 (고객사 프로필의 시정명령 미이행 여부 기준)
투자 감경	최대 40%	보호 투자·보호체계 운영·추가 안전조치를 고려해 기준금액의 최대 40% 감경. 위반 전 3개 사업연도 노력을 보며 고의·중과실 위반은 제외. 상한 기준 예시 9,000만 원
ISMS-P 인증 감경	최대 30%	현재 미인증. ISMS-P 인증에 따른 감경 상한은 최대 30%(개정 전 50%). 중요 개인정보처리자 대상 인증 의무화는 2027-07-01 시행 예정

항목	값	근거·설명
유사 처분 사례 과징금	4건	최소 5,750만 원, 중앙값 3억 2,522만 원, 최대 213억 8,500만 원. 참고 사례를 뺀 등급(동일 결함·같은 유형·관련 통제)의 처분 사례 중 과징금이 있는 것만 집계. 사례 기업과 고객사의 매출 규모가 달라 예상 부과액이 아니라 '유사 사례에서 실제로 나온 금액'임 유사 사례 중앙값이 이 고객사의 법정 상한보다 큼. 사례 기업이 더 커서 생긴 차이이므로 사례 금액을 고객사 예상 과징금처럼 쓰면 안 됨 (상한을 넘는 과징금은 불가능)

4.4 조치 우선순위

순위	점검 항목	위험도	사례 근거	점수	여기까지 조치 시
1	불충분한 권한 검증	상	동일 결함	4.5	리스크 100.0% 감소

점수 = 심각도(상3·중2·하1) × 개인정보 자산(예 1.0·아니오 0.3) × (1 + 0.5 × 사례 근거(동일 결함 1.0·같은 유형 0.7·관련 통제 0.5·참고 0.3·없음 0.2)). 점수는 조치 순서를 정하기 위한 상대값이며 금액이 아닙니다.

4.5 산정 가정과 제외 항목

- 고객사 프로필(매출·정보주체 수 등)은 모의 교육 플랫폼 가정값
- 법정 상한은 최대치이며 예상 부과액이 아님
- 같은 조항에 걸린 취약점이 여러 개여도 법정 상한은 한 번만 적용
- 유사 사례 금액은 대부분 개정법 시행(2026-09-11) 이전 구법 기준 처분
- 투자 감경 예시값은 법정 상한에 최대 감경률을 적용한 것으로, 실제 감경은 기준금액에 적용됨
- 우선순위 점수는 조치 순서를 정하기 위한 상대 점수이며 금액이 아님

제외 항목	사유
약한 비밀번호 정책	상태가 '양호'라 노출액 계산에서 제외